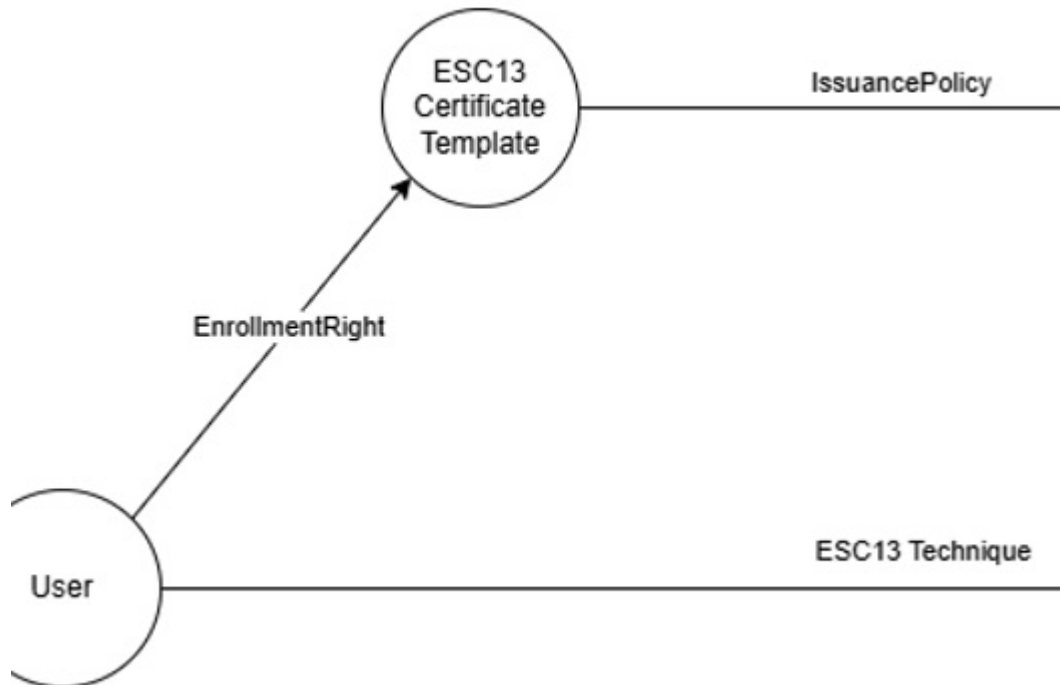


Детектирование техники ADCS ESC13

 purpleshift.io/ru/articles/2024-07-16-esc13

16 июля 2024 г.



1. [Статьи](#)/

В феврале этого года исследователи из Specter Ops подсветили очередную технику абыюза ADCS и дали ей название [ESC13](#). Для понимания того, как работает эта техника, нужно разобраться в двух понятиях.

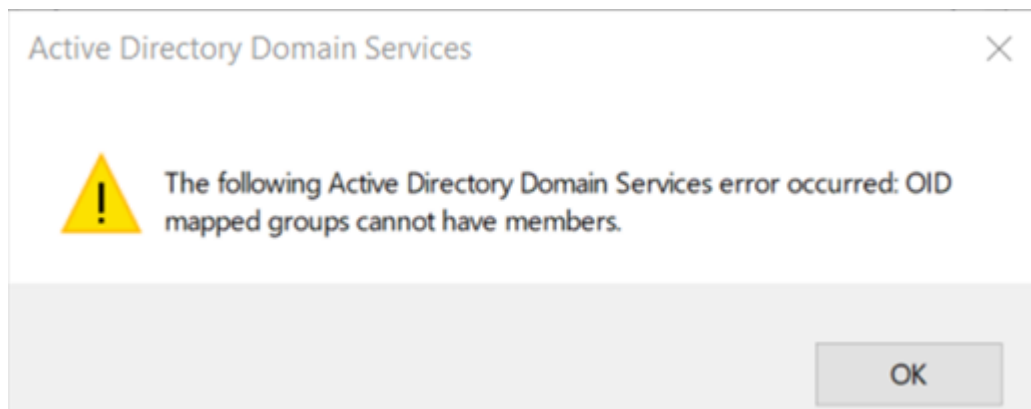
Первое - это объект **Issuance Policy**, который используется для управления доступом. Система может потребовать от пользователя предоставить сертификат с определенной **Issuance Policy**, чтобы гарантировать, что доступ предоставлен только правильным, авторизованным пользователям.

Второе понятие - это атрибут [msDS-OIDToGroupLink](#).

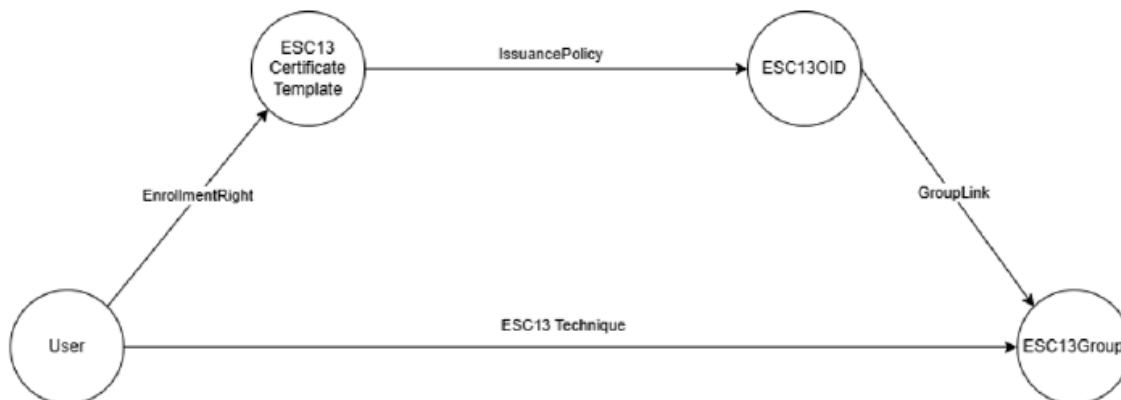
Класс **Issuance Policy** в Active Directory содержит атрибут **msDS-OIDToGroupLink**, и его можно использовать для линковки **Issuance Policy** с группой AD. Таким образом, системы будут авторизовать пользователей, как будто они включены в группу. Работать это будет в случае, если пользователь предоставит сертификат с необходимой **Issuance Policy**.

Данный механизм используется в [Microsoft Authentication Mechanism Assurance \(AMA\)](#). Создан он был для защиты ресурсов, предоставляя права только

пустым группам AD и заставляя администраторов ресурсов использовать аутентификацию с помощью сертификатов. Поэтому в группы AD, слинкованные с **Issuance Policy**, невозможно добавить пользователей - при попытке добавления появится сообщение об ошибке:



Таким образом, если у нас есть пользователь, который может запросить сертификат, используя **Certificate Template** (ESC13) с возможностью аутентификации, и этот шаблон содержит **Issuance Policy** (ESC13OID) с линкованной группой (ESC13Group), то пользователь может получить access token с SID группы (ESC13Group), хотя формально он не является членом данной группы. Схематично можно представить это так:



Выглядеть полученный TGT будет так, как будто его скрафтили, а именно - список групп внутри PAC и список реальных групп пользователя не будут соответствовать, что напоминает классический Golden Ticket.

```

PS C:\work\ADCS> .\Rubeus.exe describe /servicekey:84bc130a74e533ea592eca88a2825e224d5d37b669e78709a5cfd89e63ee5ad /ticket:doIF3jCCBdqgAwIBBaEDAgEwoIE/TCCBP1hqqT1MIIE8aADAgEFoQwBC1RFUIQuTE9DQUYiHzAdoAMCAQKHfjAUGWZrcmJ0Z3QbCnRlc3QubG9jYWYt
Rubeus
v2.2.3

[*] Action: Describe Ticket

ServiceName      : krbtgt/test.local
ServiceRealm     : TEST.LOCAL
UserName         : User
UserRealm        : TEST.LOCAL
StartTime        : 5/27/2024 12:43:07 AM
EndTime          : 5/27/2024 10:43:07 AM
RenewTill        : 6/3/2024 12:43:07 AM
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)      : 6JyvLSlvytWp6ixN0Mq56Q==
Decrypted PAC    :
LogonInfo        :
  LogonTime       : 5/27/2024 12:41:26 AM
  LogoffTime      :
  KickOffTime     :
  PasswordLastSet : 8/22/2022 6:39:12 PM
  PasswordCanChange : 8/23/2022 6:39:12 PM
  PasswordMustChange :
  EffectiveName   : user
  FullName        : user
  LogonScript     :
  ProfilePath     :
  HomeDirectory   :
  HomeDirectoryDrive :
  LogonCount      : 297
  BadPasswordCount : 0
  UserId          : 1104
  PrimaryGroupId  : 513
  GroupCount      : 3
  Groups          : 3110

```

```

PS C:\work\ADCS> Get-ADGroup -Identity S-1-5-21-837510782-1078370389-2529773014-3110 -Properties members

DistinguishedName : CN=ESC13Group,CN=Users,DC=test,DC=local
GroupCategory     : Security
GroupScope        : Universal
Members           : {}
Name              : ESC13Group
ObjectClass       : group
ObjectGUID        : 9245eb1e-2920-4d48-a1d9-2b8d711af72f
SamAccountName    : ESC13Group
SID               : S-1-5-21-837510782-1078370389-2529773014-3110

```

```

PS C:\work\ADCS> Get-ADUser User -Properties MemberOf

DistinguishedName : CN=user,CN=Users,DC=test,DC=local
Enabled           : True
GivenName         : user
MemberOf          : {}
Name              : user
ObjectClass       : user
ObjectGUID        : 2b80120d-f1c6-4cff-b5f3-f8f798e078c2
SamAccountName    : user
SID               : S-1-5-21-837510782-1078370389-2529773014-1104
Surname           :
UserPrincipalName : user@test.local

```

Например, есть утилита [FindGT](#) Александра Родченко, которая срабатывает на такой билет, да и в большинстве случаев данная логика хорошо работает. Если же данный механизм (АМА) действительно необходим и используется, то детекты на такие билеты можно фильтровать.

```

DEBUG Successfully negotiated credential to token: 844
Token on User S-1-5-21-837510782-1078370389-2529773014-1104 in Session 0x1317f0 contains S-1-5-21-837510782-1078370389-2529773014-3110 but doesn't
DEBUG Successfully got a credential handle to LUID: 0x7b5fd
DEBUG Successfully negotiated credential to token: 1564

```

Для аудита подобных, потенциально эксплуатируемых конфигураций, отлично подойдет скрипт от Jonas Bülow Knudsen [Check-ADCSESC13.ps1](#).

Детектировать эту атаку во время эксплуатации, а не на этапе аудита, возможно по изменениям соответствующих объектов в AD. Например, при правильно настроенном аудите объектов AD и ADCS, можем получить событие добавления **Issuance Policy** в **Certificate Template**:

```
A directory service object was modified.

Subject:
  Security ID:      TEST\Administrator
  Account Name:     Administrator
  Account Domain:   TEST
  Logon ID:         0x122A1C

Directory Service:
  Name:  test.local
  Type:  Active Directory Domain Services

Object:
  DN:      CN=ESC13,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local
  GUID:    CN=ESC13,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local
  Class:   pKICertificateTemplate

Attribute:
  LDAP Display Name:  msPKI-Certificate-Policy
  Syntax (OID):       2.5.5.12
  Value:              1.3.6.1.4.1.311.21.8.12773973.13684807.8602010.16220773.4277172.220.2725255.12161679

Operation:
  Type:  Value Added
  Correlation ID:  {c663333d-2a55-44c8-8446-21936e28b008}
  Application Correlation ID: -
```

По OID из события можно найти нужный объект и посмотреть, есть ли у него линк с какой-то группой:

```
PS C:\Users\Administrator> Get-ADObject -Filter "msPKI-Cert-Template-OID -eq '1.3.6.1.4.1.311.21.8.12773973.13684807.8602010.16220773.4277172.220.2725255.12161679'" -SearchBase "CN=OID,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local" -Properties DisplayName,msDS-OIDToGroupLink

DisplayName      : ESC13OID
DistinguishedName : CN=12161679.752F37A339FDCE4629FF4F41F36A40A6,CN=OID,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local
msDS-OIDToGroupLink : CN=ESC13Group,CN=Users,DC=test,DC=local
Name              : 12161679.752F37A339FDCE4629FF4F41F36A40A6
ObjectClass       : msPKI-Enterprise-01d
ObjectGUID        : ad648125-1e5a-486d-977f-f5e213ccff97
```

Также необходимо следить за изменением атрибута **msDS-OIDToGroupLink**:

A directory service object was modified.

Subject:

Security ID: TEST\Administrator
Account Name: Administrator
Account Domain: TEST
Logon ID: 0x112415

Directory Service:

Name: test.local
Type: Active Directory Domain Services

Object:

DN: CN=12161679.752F37A339FDCE4629FF4F41F36A40A6,CN=OID,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local
GUID: CN=12161679.752F37A339FDCE4629FF4F41F36A40A6,CN=OID,CN=Public Key Services,CN=Services,CN=Configuration,DC=test,DC=local
Class: msPKI-Enterprise-Oid

Attribute:

LDAP Display Name: msDS-OIDtoGroupLink
Syntax (OID): 2.5.5.1
Value: CN=ESC13Group,CN=Users,DC=test,DC=local

Operation:

Type: Value Added
Correlation ID: {28e893c0-d14b-4922-a3bd-2f56d14425dc}
Application Correlation ID: -

Не лишним будет проверять опубликованные **Certificate Templates**, с потенциально эксплуатируемой конфигурацией и содержащие **Issuance Policy**:

msPKI-RA-Signature = 0

msPKI-Minimal-Key-Size = 2048

pKIDefaultKeySpec = 1

pKIExpirationPeriod = 1 Years

pKIOverlapPeriod = 6 Weeks

cn = ESC13

distinguishedName = ESC13

msPKI-Cert-Template-OID =

1.3.6.1.4.1.311.21.8.12773973.13684807.8602010.16220773.4277172.220.3949383.8404967 ESC13

pKIKeyUsage = a0

displayName = ESC13

templateDescription = User

pKIExtendedKeyUsage =

1.3.6.1.5.5.7.3.2 Client Authentication

1.3.6.1.5.5.7.3.4 Secure Email

1.3.6.1.4.1.311.10.3.4 Encrypting File System

pKIDefaultCSPs =

Microsoft Enhanced Cryptographic Provider v1.0

Microsoft Base Cryptographic Provider v1.0

msPKI-Supersede-Templates =

msPKI-RA-Policies =

msPKI-RA-Application-Policies =

msPKI-Certificate-Policy =

1.3.6.1.4.1.311.21.8.12773973.13684807.8602010.16220773.4277172.220.2725255.12161679 ESC13OID

И следить, какие пользователи их запрашивают, например, по CSR из базы данных СА. Но стоит учесть, что не все поля обязательны для заполнения, поэтому части из них может и не быть.

```

Attribute[0]: 1.3.6.1.4.1.311.13.2.3 (OS Version)
  Value[0][0], Length = c
    6.2.9200.2

Attribute[1]: 1.3.6.1.4.1.311.21.20 (Client Information)
  Value[1][0], Length = 2f
  Client Id: = 5
  ClientIdDefaultRequest -- 5
  User: TEST\user
  Machine: win11.test.local
  Process: certify.exe

Attribute[2]: 1.3.6.1.4.1.311.13.2.2 (Enrollment CSP)
  Value[2][0], Length = 58
  CSP Provider Info
  KeySpec = 2
  Provider = Microsoft Strong Cryptographic Provider
  Signature: UnusedBits=0

Attribute[3]: 1.2.840.113549.1.9.14 (Certificate Extensions)
  Value[3][0], Length = 151
Certificate Extensions: 7
  1.3.6.1.4.1.311.21.7: Flags = 0, Length = 31
  Certificate Template Information
    Template=ESC13(1.3.6.1.4.1.311.21.8.12773973.13684807.8602010.16220773.4277172.220.3949383.8404967)
    Major Version Number=100
    Minor Version Number=12

  2.5.29.37: Flags = 0, Length = 22
  Enhanced Key Usage
    Client Authentication (1.3.6.1.5.5.7.3.2)
    Secure Email (1.3.6.1.5.5.7.3.4)
    Encrypting File System (1.3.6.1.4.1.311.10.3.4)

  2.5.29.15: Flags = 1(Critical), Length = 4
  Key Usage
    Digital Signature, Key Encipherment (a0)

  2.5.29.32: Flags = 0, Length = 2d
  Certificate Policies
    [1]Certificate Policy:
      Policy Identifier=ESC130ID

  1.3.6.1.4.1.311.21.10: Flags = 0, Length = 28
  Application Policies
    [1]Application Certificate Policy:
      Policy Identifier=Client Authentication
    [2]Application Certificate Policy:
      Policy Identifier=Secure Email
    [3]Application Certificate Policy:
      Policy Identifier=Encrypting File System

```

Также можно посматривать на необычные LDAP-запросы, например по поиску **Issuance Policy** с заполненным атрибутом **msDS-OIDToGroupLink** или не дефолтных **Security Descriptor**.